
Analyse de Risques de Biolab Analytics

Auteurs :
Malek Kahia

Date :
28 septembre 2026

Année Universitaire 2025-2026

Analyse réalisée selon la méthode EBIOS Risk Manager (ANSSI, 2018)

Table des matières

1	Atelier 1 — Socle de sécurité et Événements Redoutés (ER)	2
1.1	Identification des Valeurs Métier (VM)	2
1.2	Cartographie des Actifs Supports	3
1.3	Événements Redoutés (ER) — Détail complet	3
2	Atelier 2 — Sources de Risque (SR) et Objectifs Visés (OV)	6
2.1	Sources de Risque	6
2.2	Couples SR / OV	7
3	Atelier 3 — Scénarios Stratégiques	8
3.1	Tableau de synthèse des scores des Parties Prenantes	8
3.2	Scénarios Stratégiques	8
4	Atelier 4 — Scénarios Opérationnels	11
5	Atelier 5 — Traitement des Risques	13
5.1	Matrice de Risque Initiale	13
5.2	Plan de Traitement — Classification MoSCoW	13
5.3	Matrice de Risque Résiduelle	15
5.4	Tableau de Bord — Synthèse	15
	Annexe — Références réglementaires et normatives	16

1 Atelier 1 — Socle de sécurité et Événements Redoutés (ER)

1.1 Identification des Valeurs Métier (VM)

ID	Valeur Métier	Description	Criticité
VM1	Données médicales & génétiques	Séquences ADN (fichiers FASTA), résultats bruts (MinIO)	*** Critique
VM2	Données administratives patients	Identités, dossiers médicaux, facturation (base <code>patient-db</code>)	*** Grave
VM3	Propriété intellectuelle scientifique	Code du nœud de calcul (pipeline séquençage/GC/variant), scripts d'automatisation	*** Grave
VM4	Continuité des opérations	Capacité à dérouler le workflow bout-en-bout (intake → livraison) dans les délais	*** Grave
VM5	Réputation & conformité	Certification HDS, conformité RGPD	*** Critique

1.2 Cartographie des Actifs Supports

```

VM1 (Données ADN / médicales)
|--- Noeud de calcul <- FAILLE (flux non chiffré)
|--- Stockage MinIO (HTTPS, cert. CA interne) <- FAILLE CRITIQUE
|--- Chiffrement maison (XOR statique) <- FAILLE CRITIQUE
|--- Serveur SFTP bidirectionnel (inbound/outbound) <- FAILLE CRITIQUE
|   (clé SSH UNIQUE partagée biolab_admin <-> hopital_saint_martin
|   + clé résiduelle de l'ancien prestataire jamais révoquée)
|--- Réseau net-sci-admin (10.10.1.0/24) <- MEME VLAN que postes
|   admin, bio-info, technicien, biologiste, IT, et l'automate

VM2 (Données administratives)
|--- Base patient-db
|--- LIMS
|--- Postes administratifs (net-sci-admin, dual-homés net-dmz)

VM3 (Propriété intellectuelle)
|--- Dépôts de code (scripts workstations)
|--- Bastion + serveur de logs (FUSIONNES) <- FAILLE

VM4 (Continuité)
|--- Infrastructure réseau globale <- FAILLE (réseau plat net-sci-admin)
|--- Pare-feu (perimetre limite au port public hôte 2222 -> SFTP)
|--- Automate de laboratoire (Modbus TCP) <- FAILLE CRITIQUE
|   (aucune authentification, lecture ET écriture libres)
|--- Journalisation (syslog UDP/514, non chiffre, non authentifié)

VM5 (Réputation & conformité)
|--- LDAP / IAM (comptes individualisés, groupe "employees" plat)
|--- PKI interne auto-signée (CA + certs LIMS)

```

1.3 Événements Redoutés (ER) — Détail complet

VM1 — Données médicales & génétiques

ER1.1 — Perte de Confidentialité des données ADN/médicales

Scénario : vol ou fuite des séquences génétiques et des résultats d'analyse

Impacts directs :

- Violation du RGPD Art. 9 (données de santé = catégorie spéciale) → amendes jusqu'à 4 % du CA mondial + poursuites pénales.
- Perte immédiate de la certification HDS → résiliation des contrats hôpitaux.
- Chantage aux patients (donnée ADN à valeur permanente).

Gravité :  G4 (Critique). Peut entraîner la fermeture définitive du laboratoire.

ER1.2 — Perte d'Intégrité des résultats d'analyse

Scénario : modification silencieuse de résultats (valeurs numériques, interprétations diagnostiques).

Impacts directs :

- Erreur de diagnostic → mise en danger de la vie des patients.
- Engagement de la responsabilité pénale des biologistes valideurs (Art. 226-17 CP).
- Rappel massif de résultats → paralysie opérationnelle et perte de confiance.

Gravité : 4 G4 (Critique). Dimension médico-légale majeure.

ER1.3 — Perte de Disponibilité de l'infrastructure de calcul

Scénario : ransomware ou déni de service exploitant l'absence de segmentation du réseau.

Impacts directs :

- Retards de rendu des résultats aux hôpitaux.
- Examens urgents non réalisables.
- Pertes financières directes + pénalités contractuelles.

Gravité : 3 G3 (Grave). Surmontable si un PRA est opérationnel.

ER1.4 — Perte d'Intégrité/Disponibilité de l'automate de laboratoire

Scénario : l'automate ne dispose **d'aucune authentification**. N'importe quel poste compromis peut lire, mais aussi **écrire**, ces registres sans le moindre identifiant.

Impacts directs :

- Falsification de la température → destruction silencieuse d'échantillons biologiques irremplaçables.
- Falsification du statut machine → décisions opérationnelles erronées.
- Sabotage physique.

Gravité : 4 G4 (Critique). Atteinte à l'intégrité d'échantillons non reproductibles.

VM2 — Données administratives

ER2.1 — Perte de Confidentialité des dossiers administratifs

Scénario : accès non autorisé aux dossiers patients.

Impacts directs :

- Usurpation d'identité.
- Notification obligatoire à la CNIL (Art. 33 RGPD) + amendes.

Gravité : 3 G3 (Grave).

ER2.2 — Perte d'Intégrité des dossiers administratifs

Scénario : modification des prescriptions, des identités patients ou des factures, directement sans traçabilité.

Impacts directs :

- Erreurs d'attribution de résultats, facturation frauduleuse.

Gravité : 2 G2 (Significatif).

VM3 — Propriété intellectuelle

ER3.1 — Vol des algorithmes propriétaires

Scénario : exfiltration du code du nœud de calcul et des scripts d'automatisation.

Impacts directs :

- Perte d'avantage concurrentiel (années de R&D volées).
- Impossibilité de valoriser la PI (brevets, licences).

Gravité : 3 G3 (Grave).

Valeur métier	Événement redouté	Catégories d'impact	Gravité
Données médicales & génétiques	Perte de confidentialité (clé SSH partagée, XOR, TLS non vérifié)	Vie privée, image, juridique (RGPD Art. 9, HDS, pénal)	4
	Perte d'intégrité des résultats (Adminer, LIMS sans signature)	Santé/sécurité, responsabilité pénale, image	4
	Perte de disponibilité HPC (réseau plat)	Missions/services, financier (SLA)	3
	Sabotage de l'automate (Modbus non authentifié)	Intégrité échantillons, sécurité sanitaire	4
Données administratives patients	Perte de confidentialité (Adminer exposé)	Vie privée, juridique (RGPD Art. 33)	3
	Perte d'intégrité (Adminer, LDAP plat)	Missions/services, juridique	2
Propriété intellectuelle	Vol des algorithmes (bastion fusionné)	Patrimoine intellectuel, financier	3

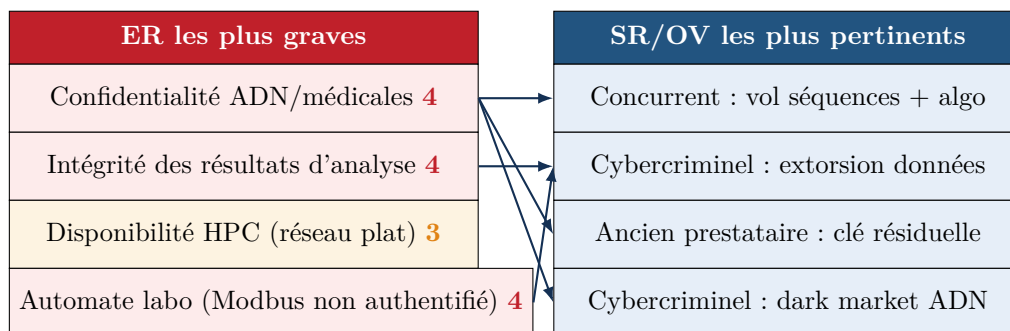
2 Atelier 2 — Sources de Risque (SR) et Objectifs Visés (OV)

2.1 Sources de Risque

Source de risque	Objectifs visés	Motivation	Ressources	Pertinence
Concurrent (SR2)	• Vol des séquences génétiques et des algorithmes propriétaires	Fortement motivé	Ressources importantes	Très pertinent
Cybercriminel organisé (SR1)	• Chiffrement + extorsion des données médicales • Vente de données ADN	Assez motivé	Ressources significatives	Plutôt pertinent
Ancien prestataire (SR4)	• Revente ou usage opportuniste de l'accès conservé	Variable / opportuniste	Accès déjà acquis	Très pertinent
Hacktiviste / Curieux (SR3)	• Divulcation publique de données de santé à des fins idéologiques	Peu motivé	Ressources limitées	Peu pertinent

2.2 Couples SR / OV

Source	Objectif Visé principal	ER ciblé	Justification
SR1	Chiffrement + extorsion des données médicales (mouvement latéral, réseau plat)	ER1.1 + ER1.3	Santé = cible prioritaire ransomware
SR1	Vente de données ADN sur dark markets (interception SFTP / clé faible)	ER1.1 + ER2.1	Donnée permanente, très lucrative
SR2	Vol des séquences génétiques et algorithmes	ER1.1 + ER3.1	Avantage compétitif majeur en génomique
SR2	Sabotage de résultats d'analyses	ER1.2	Nuire à la réputation / avantage concurrentiel
SR3	Divulgence publique de données de santé	ER1.1 + ER2.1	Indignation liée au traitement des données sensibles
SR4	Réutilisation de l'accès résiduel (clé SSH ancien prestataire)	ER1.1 + ER1.2 + ER3.1	Accès direct, légitime en apparence, sans exploitation technique

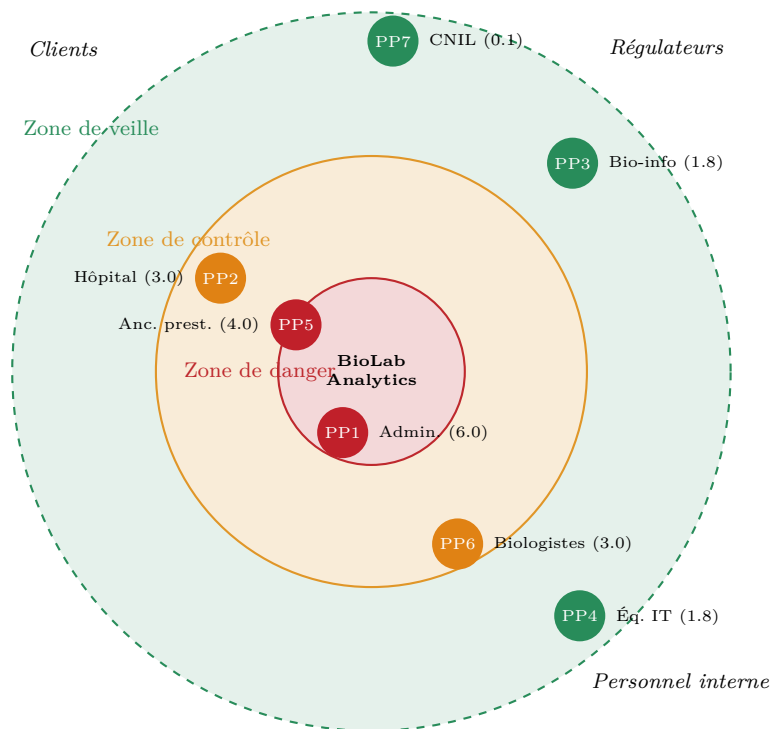


3 Atelier 3 — Scénarios Stratégiques

3.1 Tableau de synthèse des scores des Parties Prenantes

PP	Partie Prenante	D	P	M	C	Score	Expo	Fiab
PP1	Personnel administratif	2	3	1	1	6.0	6	1
PP5	Ancien prestataire externe	1	4	1	1	4.0	4	1
PP2	Hôpital partenaire	4	3	2	2	3.0	12	4
PP6	Biologistes / Techniciens	3	2	1	2	3.0	6	2
PP3	Bio-informaticiens	4	4	3	3	1.8	16	9
PP4	Équipe IT (bastion, PKI, pare-feu)	4	4	3	3	1.8	16	9
PP7	CNIL / Autorités	1	1	4	4	0.1	1	16

$Score = Exposition (D \times P) / Fiabilité (M \times C)$. PP5 est une addition motivée par la maquette : bien que peu « dépendant » de BioLab (D=1), son niveau de pénétration est maximal (P=4, accès SSH toujours valide) et sa fiabilité est nulle (M=1, C=1, aucune relation contractuelle active) — d'où un classement en **Zone de danger**, juste derrière le personnel administratif.



3.2 Scénarios Stratégiques

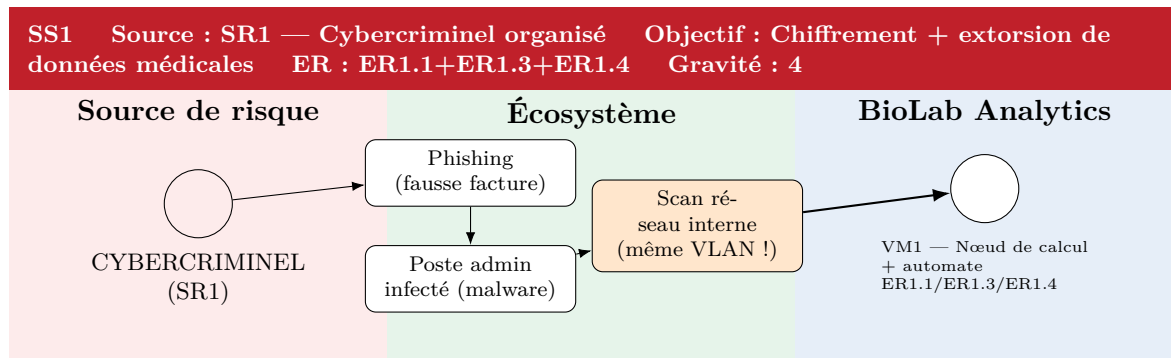
Scénario Stratégique SS1 — Infiltration par le personnel administratif

Couple : SR1 → PP1 (● Zone de danger) → VM1 + VM2.

Logique : Attaque par ingénierie sociale, puis pivotement direct vers le nœud de calcul et l'automate

(même réseau plat `net-sci-admin`).

ER ciblés : ER1.1 + ER1.3 + ER1.4.

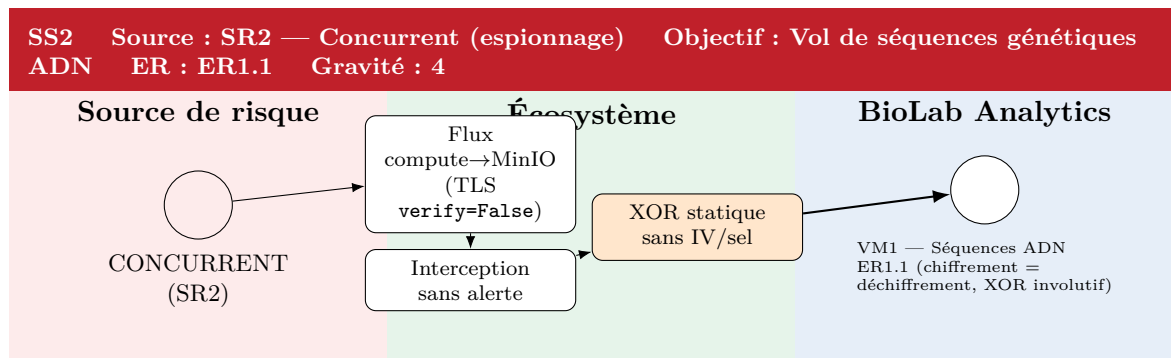


Sc nario Strat gique SS2 — Exploitation de la cha ne cryptographique d faillante

Couple : SR2 → Chiffrement maison / MinIO (VM1) → (● Zone de contr le :  quipe IT/Bio-info).

Logique : L'attaquant cible directement les failles cryptographiques (XOR statique, TLS non v rifi ).

ER cibl s : ER1.1.

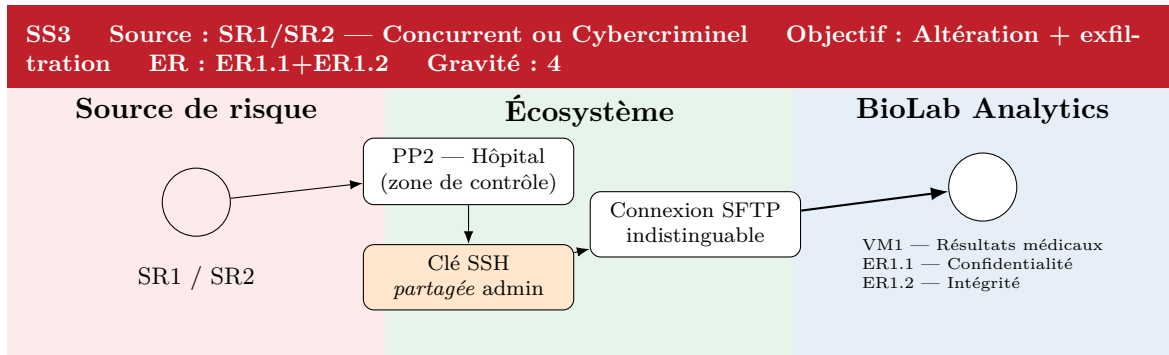


Scénario Stratégique SS3 — Pivot depuis un hôpital partenaire

Couple : SR1/SR2 → PP2 (● Zone de contrôle) → VM1.

Logique : Réutilisation de la clé SSH partagée entre biolab_admin et hopital_saint_martin pour se connecter au SFTP en toute légitimité apparente.

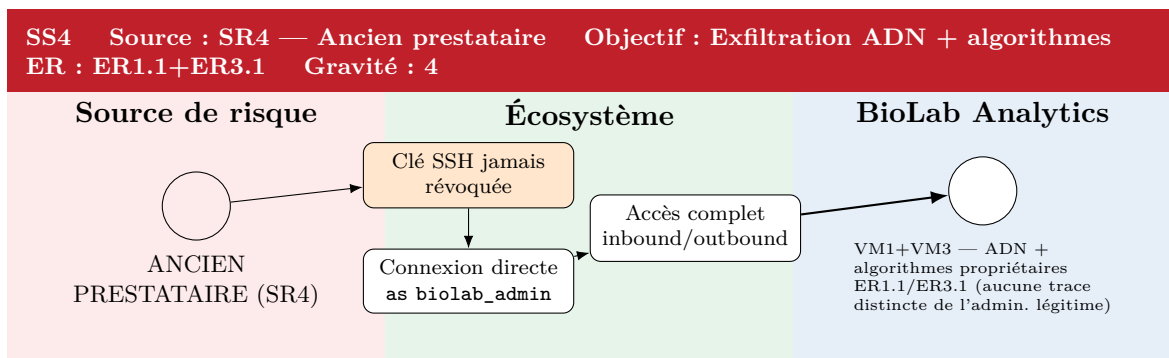
ER ciblés : ER1.1 + ER1.2.

**Scénario Stratégique SS4 — Réutilisation de l'accès résiduel de l'ancien prestataire**

Couple : SR4 → PP5 (● Zone de danger) → VM1 + VM3.

Logique : L'ancien prestataire se reconnecte directement en tant qu'administrateur légitime du SFTP, sa clé n'ayant jamais été révoquée — **aucune intrusion technique n'est nécessaire.**

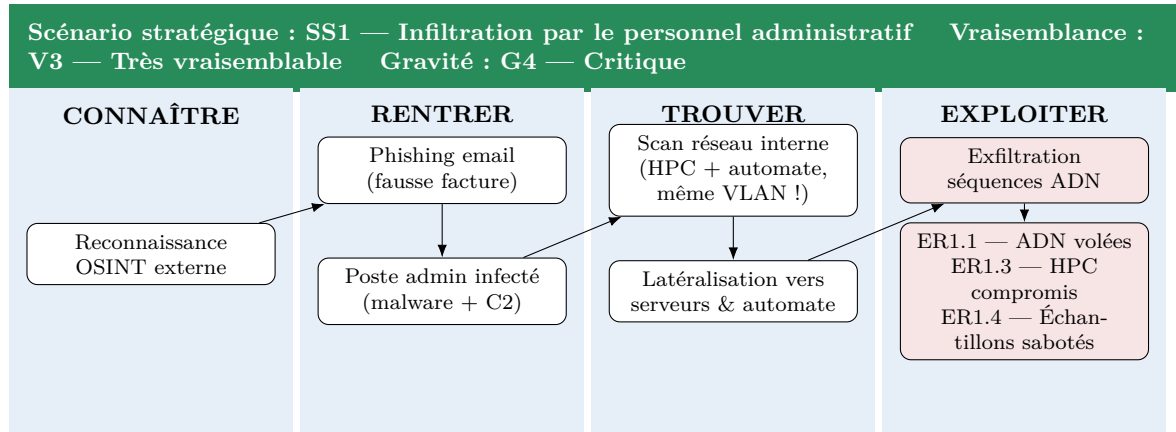
ER ciblés : ER1.1 + ER3.1.



4 Atelier 4 — Scénarios Opérationnels

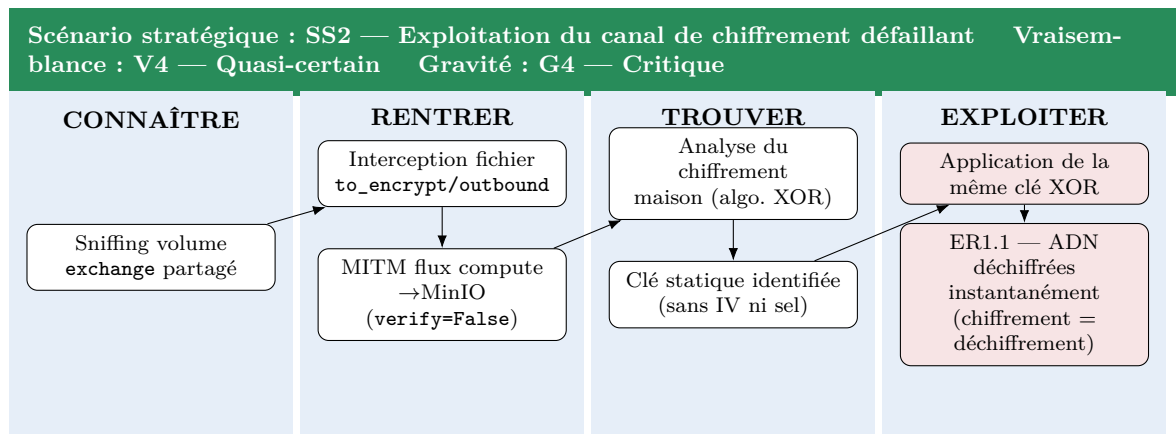
Scénario A — réseau plat (faille VLAN)

Source de risque : SR1 | **PP exploitée** : PP1 | **ER ciblés** : ER1.1 + ER1.3 + ER1.4 | **Vraisemblance** : V3 (Très vraisemblable)



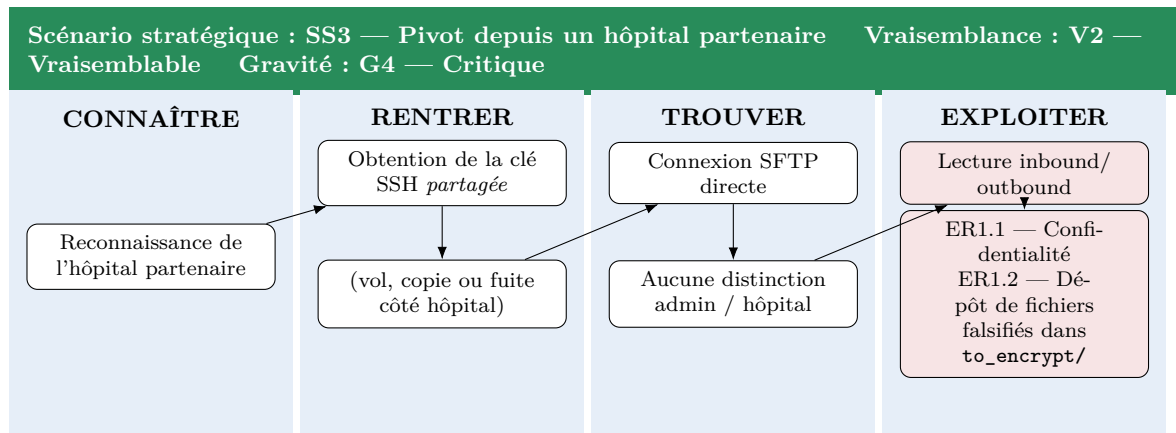
Scénario B — La brèche cryptographique (chiffrement maison + PKI non vérifiée)

Source de risque : SR1/SR2 | **PP exploitée** : Canal chiffrement maison + MinIO | **ER ciblés** : ER1.1 | **Vraisemblance** : V4 (Quasi-certain)



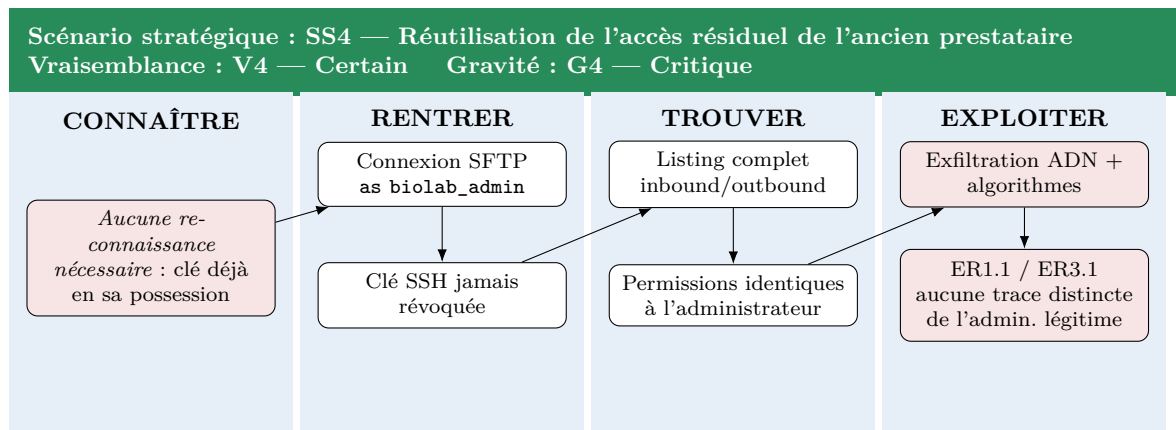
Scénario C — Le pivot depuis le réseau hospitalier

Source de risque : SR1/SR2 | PP exploitée : PP2 | ER ciblés : ER1.1 + ER1.2 | Vraisemblance : V2 (Vraisemblable)



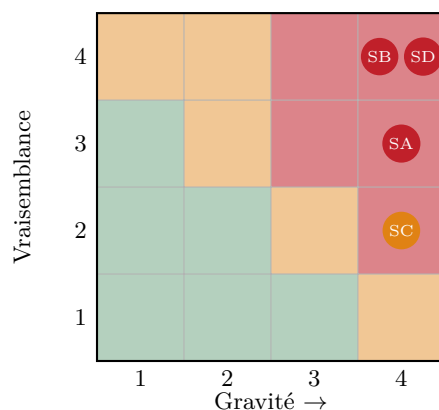
Scénario D — La porte dérobée de l'ancien prestataire

Source de risque : SR4 | PP exploitée : PP5 | ER ciblés : ER1.1 + ER3.1 | Vraisemblance : V4 (Certain)



5 Atelier 5 — Traitement des Risques

5.1 Matrice de Risque Initiale



Sc.	Description
SA	Réseau plat — V3/G4 — Absence de segmentation VLAN
SB	Crypto maison — V4/G4 — XOR statique + PKI non vérifiée sur MinIO
SC	Pivot hôpital — V2/G4 — Clé SSH partagée biolab_admin/hôpital
SD	Porte dérobée ancien prestataire — V4/G4 — Clé SSH jamais révoquée

Zones : ■ Critique ■ Élevé ■ Acceptable

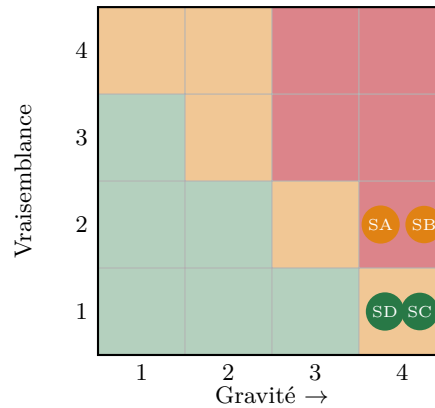
5.2 Plan de Traitement — Classification MoSCoW

MUST HAVE — Remédiation immédiate (0–3 mois)

R1 — Segmentation réseau (Règles 22 & 25) : scission de `net-sci-admin` en sous-réseaux étanches (calcul, administration, automate, postes utilisateurs) avec filtrage strict ; suppression du dual-homing direct de l'admin, de l'hôpital et de l'ancien prestataire sur `net-dmz`, afin que leur trafic transite réellement par le pare-feu.

R2 — Remplacement du chiffrement maison par AES-256-GCM (Règles 7 & 31) au lieu du XOR statique sans IV/sel.

R3 — Révocation immédiate et individualisation des clés SSH SFTP (Règle 31) : suppression immédiate de la clé de l'ancien prestataire des `authorized_keys` de `biolab_admin` ; génération d'une paire de clés *distincte* pour l'admin et pour l'hôpital ; rotation périodique automatisée.

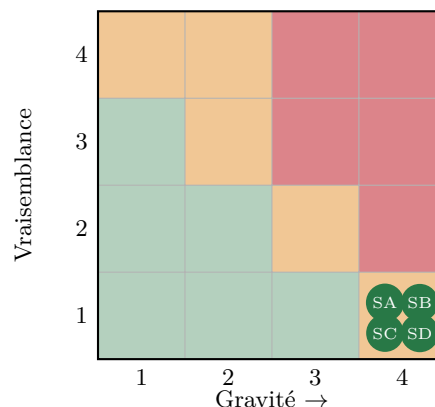


Jalon 3 mois — après $R1$, $R2$, $R3$: $SD V4 \rightarrow V1$ (clé révoquée : le scénario le plus trivial est aussi le plus vite traité) ; $SC V2 \rightarrow V1$ (clés individualisées) ; $SB V4 \rightarrow V2$ (XOR éliminé, mais `verify=False` sur `MinIO` toujours actif) ; $SA V3 \rightarrow V2$ (réseau segmenté, mais pas encore de détection — SIEM non déployé).

SHOULD HAVE — Traitement prioritaire (3–6 mois)

R4 — PKI interne renforcée (Règle 34) : activation de la vérification TLS sur le flux nœud de calcul $\rightarrow$ MinIO, mise en place d'une CA intermédiaire et d'une procédure de révocation.

R5 — SIEM et restriction d'Adminer (Règle 35) : fermeture de l'accès direct à Adminer sur le réseau interne (accès via bastion uniquement, authentification renforcée) ; déploiement d'une journalisation centralisée couvrant également la DMZ et les parties externes.



Jalon 9 mois — après $R4$, $R5$: $SB V2 \rightarrow V1$ (vérification TLS réelle, `MinIO` ne peut plus être atteint sans certificat valide) ; $SA V2 \rightarrow V1$ (le SIEM détecte le scan interne et la latéralisation). SC et SD demeurent stables à $V1$ (déjà traités au jalon précédent).

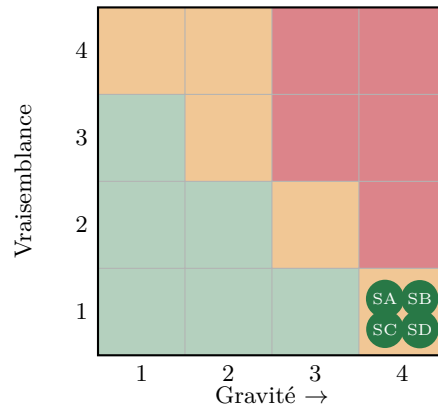
COULD HAVE — Amélioration continue (6–12 mois)

R6 — Sensibilisation et formation : anti-phishing, bonnes pratiques de gestion des clés, sensibilisation étendue au personnel de l'hôpital partenaire.

R7 — PCA/PRA : stratégie de sauvegarde 3-2-1, RPO/RTO définis, y compris une procédure de vérification manuelle des échantillons en cas de compromission de l'automate.

R8 — Formalisation de la réponse aux incidents et procédure d'offboarding (Règle 40) : PSSI, procédure *systématique* de révocation des accès prestataires en fin de contrat (pour empêcher la répétition du scénario SD), contact CERT Santé.

5.3 Matrice de Risque Résiduelle



Sc.	Risque résiduel	Traitements appliqués
SA'	V1/G4 — Acceptable	R1+R5+R6 : segmentation + SIEM + formation
SB'	V1/G4 — Acceptable	R2+R3+R4 : AES-256 + rotation clés + PKI
SC'	V1/G4 — Acceptable	R3+R4+R6 : clés individualisées + PKI + formation hôpital
SD'	V1/G4 — Acceptable	R3+R8 : révocation immédiate + offboarding formalisé

5.4 Tableau de Bord — Synthèse

Remédiation	Scénario	Priorité	Délai	Difficulté	Coût
R1 — Segmentation	SA	Must	0–3 mois	Moyenne	€€
R2 — AES-256-GCM	SB	Must	0–3 mois	Moyenne	€
R3 — Révocation & rotation clés	SB, SC, SD	Must	Immédiat	Faible	€
R4 — PKI interne	SB, SC	Should	3–6 mois	Élevée	€€€
R5 — SIEM / restriction Adminer	SA	Should	3–6 mois	Élevée	€€€
R6 — Sensibilisation	SA, SC	Could	6–12 mois	Faible	€
R7 — PCA/PRA (+ automate)	ER1.3/ER1.4	Could	6–12 mois	Élevée	€€€
R8 — Réponse incidents & offboarding	Tous, SD	Could	6–12 mois	Moyenne	€

Annexe — Références réglementaires et normatives

Référence	Pertinence pour BioLab Analytics
RGPD Art. 9	Traitement de données sensibles (génétiques = catégorie spéciale)
RGPD Art. 32	Obligation de sécurité technique et organisationnelle
RGPD Art. 33/34	Notification de violation à la CNIL sous 72 h
HDS	Certification obligatoire pour héberger des données de santé
Guide d'hygiène ANSSI	Règles 4, 7, 22, 25, 31, 34, 35, 40 — directement mobilisées dans le plan de traitement (segmentation, chiffrement, PKI, journalisation, réponse aux incidents)
ISO/IEC 27001	Référentiel SMSI applicable au contexte BioLab
CERT Santé	Signalement d'incidents cyber dans le secteur santé

Analyse réalisée selon la méthode EBIOS Risk Manager (ANSSI, 2018), appliquée à la maquette Terraform/Docker BioLab Analytics. Document à actualiser annuellement ou après tout changement majeur du système d'information.